Post-Quantum Cryptography (PQC): Understanding the Threat, Organizational Impact, and Strategies for a Quantum-Resilient Future

Article type: Cybersecurity / Information Security
Focus: Cryptographic risks, organizational impact, quantum computing, and enterprise migration strategy

1. Introduction

Cryptography is one of the foundations of modern information security. Organizations rely on encryption, digital signatures, and cryptographic key exchange to protect sensitive information, authenticate users, secure communications, and maintain the integrity of business transactions.

However, advances in quantum computing introduce a potential threat to many of the cryptographic algorithms currently used to protect digital information.

Traditional public-key cryptographic algorithms, such as RSA and Elliptic Curve Cryptography (ECC), rely on mathematical problems that are extremely difficult for conventional computers to solve. A sufficiently powerful, fault-tolerant quantum computer could use specialized quantum algorithms to solve these problems much more efficiently.

This creates a significant concern for governments, financial institutions, healthcare providers, technology companies, and other organizations that depend on cryptography to protect sensitive information.

Post-Quantum Cryptography (PQC) is an emerging approach designed to address this challenge. It involves developing and implementing cryptographic algorithms that are believed to remain secure against attacks from both conventional and quantum computers.

Organizations should not wait until large-scale quantum computers become available before taking action. They need to begin understanding their cryptographic dependencies, identifying vulnerable systems, evaluating replacement algorithms, and developing a structured migration strategy.

2. What Is Post-Quantum Cryptography?

Post-Quantum Cryptography refers to cryptographic algorithms designed to resist attacks from quantum computers.

Unlike quantum cryptography, which uses quantum-mechanical principles to secure communications, PQC uses mathematical algorithms that run on conventional computing infrastructure.

The objective is to replace or supplement existing cryptographic algorithms that could become vulnerable to sufficiently powerful quantum computers.

2.1 Why is quantum computing a threat?

Today's widely deployed public-key cryptographic systems include:

Existing algorithm	Primary purpose	Quantum computing concern
RSA	Encryption and digital signatures	Vulnerable to Shor's algorithm
ECC	Encryption-related key agreement and signatures	Vulnerable to Shor's algorithm
Diffie-Hellman	Secure key exchange	Vulnerable to Shor's algorithm
ECDH	Elliptic-curve key agreement	Vulnerable to Shor's algorithm
AES	Symmetric encryption	Weakened, but not fundamentally broken, by known quantum search algorithms
SHA-256	Cryptographic hashing	Reduced security margin against quantum search

One important distinction is that quantum computing does not affect all cryptographic algorithms equally.

Shor's algorithm presents a major concern for RSA and elliptic-curve cryptography. Grover's algorithm can provide a theoretical speedup against brute-force searching, which is why organizations should also evaluate symmetric encryption key sizes.

2.2 The Harvest Now, Decrypt Later threat

One of the most important concerns associated with quantum computing is known as Harvest Now, Decrypt Later (HNDL).

An attacker may collect encrypted information today and store it for future decryption when sufficiently powerful quantum computers become available.

For example:

1. An organization transmits sensitive information using conventional encryption.

2. An attacker captures and stores the encrypted communications.
3. The encrypted information remains stored for several years.
4. Future advances in quantum computing potentially make the captured information readable.

This is particularly concerning for information that must remain confidential for many years, including government records, intellectual property, healthcare information, financial records, and long-term business secrets.

Consequently, organizations must consider not only today's cybersecurity threats but also the future confidentiality requirements of their information.

3. NIST Post-Quantum Cryptography Standards

The National Institute of Standards and Technology (NIST) has taken a leading role in developing and standardizing quantum-resistant cryptographic algorithms.

On August 13, 2024, NIST finalized three important Post-Quantum Cryptography standards. These standards provide organizations with a foundation for migrating away from vulnerable public-key cryptographic algorithms.

CSRC+1

The three standards are:

FIPS 203

ML-KEM – Module-Lattice-Based Key-Encapsulation Mechanism

Previously known as CRYSTALS-Kyber.

- Purpose: Secure key establishment.
- Replaces vulnerable approaches to public-key key establishment.
- Enables two parties to establish a shared secret over a public channel.

FIPS 204

ML-DSA – Module-Lattice-Based Digital Signature Algorithm

Previously known as CRYSTALS-Dilithium.

- Purpose: Digital signatures.
- Provides authentication and integrity protection.

- Supports verification of digitally signed documents, software, and transactions.

FIPS 205

SLH-DSA – Stateless Hash-Based Digital Signature Algorithm

Previously known as SPHINCS+.

- Purpose: Digital signatures.
- Provides an alternative mathematical approach to ML-DSA.
- Offers an additional option for quantum-resistant digital signatures.

CSRC+1

An important point for security architects is that ML-KEM is used for key establishment, while ML-DSA and SLH-DSA are used for digital signatures. They are not interchangeable.

4. Who Will Be Affected by Post-Quantum Cryptography?

PQC is not limited to organizations operating quantum computers. Virtually every organization using public-key cryptography will eventually need to evaluate its cryptographic infrastructure.

The following industries are particularly relevant.

4.1 Financial institutions and banking

Banks and financial institutions depend heavily on cryptography to protect financial transactions, customer information, online banking, payment systems, and interbank communications.

Potential areas of impact include:

- Online banking authentication.
- Payment processing infrastructure.
- Digital certificates and PKI.
- Secure communications between financial institutions.
- Financial transaction signing.
- Long-term protection of financial records.

For example, a bank that uses RSA or ECC for secure communications must assess how these technologies will be replaced or updated to support quantum-resistant cryptography.

4.2 Government and national security

Government agencies manage highly confidential information, including national security information, classified communications, citizen records, and sensitive infrastructure information.

Potential impacts include:

- Government communication networks.
- Classified information protection.
- Military and defense systems.
- Digital identity infrastructure.
- Government-issued digital certificates.
- Long-term archival information.

Government information may require confidentiality for decades, making it particularly important to address the Harvest Now, Decrypt Later threat.

4.3 Healthcare organizations

Healthcare organizations store sensitive patient information that must remain confidential for extended periods.

Affected systems include:

- Electronic health records (EHR).
- Hospital information systems.
- Medical research databases.
- Healthcare information exchange platforms.
- Medical device communications.
- Secure connections between healthcare providers.

For example, medical records encrypted today may remain sensitive many years into the future. Organizations must therefore evaluate the confidentiality lifespan of healthcare information.

4.4 Cloud service providers and technology companies

Cloud providers and software vendors are particularly important because their cryptographic services support thousands of customers.

Potentially affected technologies include:

- Cloud key management services.
- Hardware Security Modules (HSMs).
- Secure APIs.
- TLS certificates.
- Identity and access management platforms.
- Software signing and verification.
- Database encryption.
- Cloud storage encryption.

Organizations using cloud services must also understand whether their providers support standardized PQC algorithms and have a migration roadmap.

4.5 Telecommunications and critical infrastructure

Telecommunications companies, energy providers, transportation organizations, and industrial operators depend on secure communications and long-lived technology platforms.

Potentially affected systems include:

- VPN connections.
- Network authentication.
- Secure remote access.
- Industrial control systems (ICS).
- Supervisory Control and Data Acquisition (SCADA).
- Network infrastructure.

- Embedded systems and IoT devices.

These environments can be difficult to upgrade because some devices have long operational lifecycles and limited processing capabilities.

NIST Pages+1

5. What Will Be Affected Within an Organization?

From an enterprise cybersecurity perspective, the quantum threat should be considered a cryptographic infrastructure risk rather than simply an encryption issue.

Several security technologies and business processes will require evaluation.

Technology / security area	**Potential impact**	**Required consideration**
PKI	RSA/ECC certificates and signatures may become vulnerable	Modernize certificate and signature infrastructure
TLS/HTTPS	Traditional public-key key establishment may be vulnerable	Support PQC key establishment
VPN	Traditional key exchange mechanisms may be vulnerable	Evaluate PQC-compatible protocols
IAM	Authentication certificates and signed identity tokens may be affected	Review cryptographic dependencies
PAM	Secure administrative connections and certificate-based authentication may be affected	Review privileged access infrastructure
HSM	Existing cryptographic capabilities may not support PQC	Evaluate firmware, algorithms and hardware support
Code signing	Traditional digital signatures may become vulnerable	Adopt quantum-resistant signing
Email security	S/MIME and other certificate-based protection may be affected	Evaluate encryption and signing standards

Databases	Long-term encrypted information may be exposed to future attacks	Prioritize sensitive data migration
Cloud services	Cloud cryptographic services may need updates	Validate provider PQC roadmaps
IoT and OT	Devices may lack the resources or ability to support new algorithms	Plan lifecycle replacement and upgrades

5.1 Public Key Infrastructure (PKI)

PKI is one of the most important areas organizations need to assess.

Many organizations use RSA and ECC certificates for:

- User authentication.
- Server authentication.
- Secure web communications.
- Digital signatures.
- Certificate-based VPN authentication.
- Device identity.

A quantum-capable attacker could potentially compromise the mathematical security underlying these public-key algorithms.

Organizations must therefore plan how to transition their certificate authorities, certificate profiles, certificate issuance processes, and relying systems to quantum-resistant alternatives.

5.2 Identity and Access Management (IAM)

IAM platforms use cryptography to support authentication, federation, and secure communication.

For example, organizations may use:

- SAML-based authentication.
- OpenID Connect.
- OAuth 2.0.
- Digital certificates.

- Signed authentication tokens.

Not every implementation of these technologies is automatically vulnerable. The risk depends on the underlying algorithms used for key exchange, signing, and certificate validation.

Organizations should examine the cryptographic algorithms used by their identity providers, service providers, applications, and federation infrastructure.

5.3 Privileged Access Management (PAM)

PAM platforms protect highly privileged accounts and administrative access to critical systems.

For example, platforms such as CyberArk and BeyondTrust may be deployed to manage privileged credentials, remote access, session management, and administrative authentication.

Organizations should evaluate:

- Encryption of privileged sessions.
- Secure communication between PAM components.
- Certificate-based authentication.
- SSH key management.
- Administrative access gateways.
- HSM and key management integrations.

The important consideration is that PAM products are not automatically vulnerable as a whole. Their underlying cryptographic components, integrations, protocols, and supported algorithms must be assessed.

5.4 Hardware Security Modules (HSMs) and Key Management

HSMs provide secure generation, storage, and management of cryptographic keys.

Organizations must determine whether their HSM infrastructure supports the algorithms and standards needed for PQC migration.

This includes assessing:

- Hardware compatibility.
- Firmware upgrades.

- Cryptographic module validation.
- Key lifecycle management.
- Backup and recovery procedures.
- Integration with enterprise applications.

5.5 Software development and DevSecOps

Software developers must also consider the impact of PQC on software architecture.

Applications may contain cryptographic algorithms embedded within source code, third-party libraries, APIs, and development frameworks.

Organizations should evaluate:

- Cryptographic libraries.
- Application authentication.
- Digital signing.
- Secure software updates.
- Container and package signing.
- Third-party software dependencies.

A software application that cannot support new cryptographic algorithms may require architectural changes or redevelopment.

6. What Strategies Should Organizations Implement?

Organizations should establish a formal Post-Quantum Cryptography Readiness and Migration Program.

This program should involve cybersecurity, enterprise architecture, infrastructure, application development, risk management, compliance, procurement, and third-party risk management.

The following strategy provides a practical enterprise roadmap.

Strategy 1: Establish PQC governance and executive sponsorship

PQC migration should be treated as an enterprise-wide cybersecurity initiative.

The organization should establish clear accountability and define responsibilities.

Recommended stakeholders include:

Stakeholder	Responsibility
CISO	Overall cybersecurity governance
CIO	Technology modernization and investment
Enterprise Architect	Architecture and technology standards
Security Architect	Cryptographic security design
IAM/PAM teams	Identity and privileged access assessment
Infrastructure teams	Network, server and platform upgrades
Application teams	Application and software modernization
Risk Management	Risk assessment and prioritization
Procurement	Vendor and supplier requirements
Compliance	Regulatory and standards alignment

The organization should create a PQC steering committee and establish measurable migration objectives.

Strategy 2: Conduct a Cryptographic Inventory

High priority

The first technical activity should be discovering where cryptography is used throughout the enterprise.

Many organizations do not have a complete inventory of their cryptographic dependencies.

For example, RSA and ECC may be used across applications, databases, network devices, cloud services, certificates, and third-party products.

The organization should identify:

1. Cryptographic algorithms currently deployed.
2. Applications using RSA and ECC.
3. TLS and VPN configurations.

4. Public Key Infrastructure components.
5. Digital certificates and certificate authorities.
6. Encryption key management systems.
7. HSM capabilities.
8. Cloud cryptographic services.
9. Third-party software dependencies.
10. IoT and operational technology devices.

A Cryptographic Bill of Materials (CBOM) can help document cryptographic components and their dependencies.

The inventory should include the algorithm, system owner, business purpose, data sensitivity, vendor, version, and migration requirements.

NIST's migration guidance emphasizes cryptographic discovery and the identification of vulnerable dependencies as important preparation activities.

NIST Pages+1

Strategy 3: Perform a Quantum Risk Assessment

After creating the inventory, organizations should assess the risk associated with each cryptographic dependency.

A useful approach is to evaluate systems according to:

- Sensitivity of the protected information.
- Required confidentiality lifespan.
- Exposure to external communications.
- Business criticality.
- Regulatory requirements.
- Ease of migration.
- Availability of vendor support.

For example:

System	Risk consideration	Priority

Government classified records	Long-term confidentiality	Critical
Financial customer records	Long-term confidentiality	High
Internet-facing TLS services	Public-key cryptographic exposure	High
Internal business applications	Algorithm dependencies	Medium
Legacy IoT devices	Limited upgrade capability	High if critical

The priorities shown are illustrative. Actual risk ratings must be based on the organization's information classification, threat model, and business impact assessment.

A key consideration is the data's confidentiality lifespan. Information that must remain confidential for 20 years may require earlier migration than information with a short retention period.

Strategy 4: Develop a Cryptographic Agility Strategy

Cryptographic agility is the ability to change cryptographic algorithms, protocols, and implementations without redesigning the entire technology environment.

This is one of the most important long-term strategies for quantum readiness.

Organizations should avoid hardcoding cryptographic algorithms into applications and infrastructure.

Instead, they should design systems that allow cryptographic components to be updated through controlled configuration and software changes.

Recommended practices include:

- Centralized cryptographic configuration.
- Standardized cryptographic libraries.
- Modular cryptographic architecture.
- Algorithm version management.
- Certificate lifecycle automation.
- Centralized key management.
- Documented cryptographic dependencies.
- Regular cryptographic security assessments.

For example, an application designed with cryptographic agility should be able to transition from an RSA-based key establishment mechanism to an approved PQC-based mechanism without requiring a complete application rewrite.

NIST published additional guidance on achieving cryptographic agility in June 2026.

CSRC

Strategy 5: Adopt NIST-approved PQC algorithms

Organizations should evaluate and adopt the finalized NIST PQC standards based on their intended use cases.

Existing cryptographic function	PQC migration consideration
RSA/ECC-based key establishment	Evaluate ML-KEM (FIPS 203)
RSA/ECDSA digital signatures	Evaluate ML-DSA (FIPS 204)
Alternative digital signature requirements	Evaluate SLH-DSA (FIPS 205)

Organizations should not independently invent cryptographic algorithms or implement unreviewed alternatives.

The migration should use standardized, appropriately validated implementations and follow applicable regulatory and cryptographic module requirements.

Strategy 6: Implement a Hybrid Cryptographic Approach Where Appropriate

During the transition period, organizations may consider hybrid cryptographic mechanisms.

A hybrid approach combines traditional cryptographic mechanisms with post-quantum mechanisms.

For example, a secure communication protocol may combine a conventional elliptic-curve key exchange with ML-KEM.

The objective is to maintain compatibility with existing infrastructure while introducing quantum-resistant protection.

However, hybrid cryptography must be implemented using established protocol specifications and carefully reviewed implementations. Combining algorithms incorrectly does not automatically provide stronger security.

Organizations should validate interoperability, performance, security, and vendor support before deployment.

Strategy 7: Engage Third-Party Vendors and Cloud Providers

Organizations rarely operate all cryptographic components themselves.

They depend on software vendors, cloud providers, network equipment manufacturers, SaaS platforms, and managed security providers.

Therefore, PQC readiness must extend to the supply chain.

Organizations should request information from vendors regarding:

- PQC support and implementation roadmaps.
- Support for NIST FIPS 203, 204 and 205.
- Cryptographic library compatibility.
- HSM and key management capabilities.
- TLS and VPN modernization.
- Firmware and software upgrade plans.
- Product end-of-life timelines.
- Independent security testing.

PQC requirements should also be incorporated into procurement policies, technology architecture standards, and vendor risk assessments.

Strategy 8: Test, Validate and Monitor

Before deploying PQC across the enterprise, organizations should establish a controlled testing program.

Testing should evaluate:

- Cryptographic interoperability.
- Application compatibility.
- Network performance.
- CPU and memory consumption.
- Certificate size and processing.

- Authentication performance.
- HSM compatibility.
- Disaster recovery.
- Backup and restoration.
- Security validation.

Organizations should begin with pilot implementations before moving to production environments.

This is particularly important for legacy systems, industrial environments, and business-critical applications.

Strategy 9: Establish a Formal Migration Roadmap

PQC migration should be implemented through a phased program rather than a single technology upgrade.

The following is an illustrative enterprise roadmap.

PQC enterprise migration roadmap

1. Phase 1 – Awareness and governance

0–3 months

    - Establish executive sponsorship.
    - Identify stakeholders.
    - Define PQC policies.
    - Establish migration objectives.

2. Phase 2 – Discovery and assessment

3–6 months

    - Inventory cryptographic assets.
    - Identify RSA and ECC dependencies.
    - Assess data confidentiality lifespans.
    - Identify high-risk systems.

3. Phase 3 – Architecture and planning

6–12 months

- Define PQC architecture.
- Establish cryptographic agility.
- Review vendor roadmaps.
- Develop migration priorities.

4. Phase 4 – Pilot and validation

12–18 months

- Test NIST PQC algorithms.
- Validate application compatibility.
- Test hybrid implementations where appropriate.
- Conduct security assessments.

5. Phase 5 – Enterprise migration

18 months onward

- Migrate prioritized applications.
- Upgrade infrastructure.
- Modernize PKI and certificates.
- Validate third-party dependencies.
- Retire vulnerable cryptographic implementations according to applicable timelines.

Illustrative planning periods, not mandatory regulatory deadlines. Actual timelines depend on system complexity, vendor readiness, risk and applicable requirements.

7. Regulatory, Compliance and Industry Considerations

PQC migration is increasingly becoming part of cybersecurity governance and technology modernization.

Organizations should monitor the following standards and guidance.

Framework / organization	**Relevance**

NIST FIPS 203	Post-quantum key establishment
NIST FIPS 204	Post-quantum digital signatures
NIST FIPS 205	Alternative post-quantum digital signatures
NIST IR 8547	Transition roadmap for quantum-vulnerable cryptographic standards
NIST CSWP 39	Cryptographic agility considerations
NSA CNSA 2.0	Quantum-resistant cryptographic requirements for applicable national security systems
CISA guidance	Cybersecurity preparedness and migration planning

Important migration timeline

An important recent development is NIST's publication of the finalized NIST IR 8547 in October 2026.

The report provides a transition roadmap for moving away from quantum-vulnerable cryptographic standards.

The U.S. federal government's broader target is 2035 for completing the migration, with certain high-impact systems subject to earlier deadlines.

These federal timelines do not automatically apply to every private organization. However, they are important considerations for companies working with government agencies or operating within regulated supply chains.

NIST+1

Organizations should also monitor Canadian cybersecurity guidance and applicable requirements from their regulators and industry bodies.

8. Recommended PQC Security Architecture

From an enterprise security architecture perspective, PQC should be integrated into the existing cybersecurity architecture rather than implemented as a standalone security solution.

The following illustrates the major components that should be included in a quantum-resistant enterprise architecture.

Quantum-resistant enterprise security architecture

Enterprise Governance and Risk Management

Security policies • Risk assessment • Compliance • Vendor governance

Cryptographic Agility and Management

Algorithm inventory • CBOM • Key lifecycle • Cryptographic policies

PQC Key Establishment

ML-KEM

FIPS 203

PQC Digital Signatures

ML-DSA

SLH-DSA

FIPS 204 / 205

Enterprise Security Infrastructure

PKI • IAM • PAM • HSM • TLS • VPN • Cloud • Applications

Quantum-Resilient Business Services

Secure communications • Protected data • Trusted transactions • Digital identity

The architecture demonstrates that PQC is not simply an encryption upgrade. It requires coordination across enterprise governance, cryptographic management, security infrastructure, and business applications.

9. What Should a CISO and Security Architect Do Now?

From a cybersecurity leadership perspective, the following actions should be considered priorities.

Priority	Recommended action	Expected outcome
1	Establish a PQC steering committee	Enterprise accountability
2	Conduct cryptographic discovery	Visibility into cryptographic dependencies
3	Identify RSA and ECC usage	Understanding of quantum-vulnerable components

4	Prioritize sensitive long-term data	Reduction of HNDL exposure
5	Review PKI, IAM and PAM	Identification of identity-related dependencies
6	Evaluate HSM and key management	Infrastructure readiness
7	Assess cloud and third-party vendors	Supply-chain readiness
8	Implement cryptographic agility	Easier future algorithm migration
9	Pilot NIST PQC standards	Validated migration approach
10	Establish a long-term roadmap	Controlled enterprise transition

A particularly important recommendation is to make PQC readiness part of the organization's Enterprise Architecture Review Board and Security Architecture Review process.

For example, every new application, infrastructure project, cloud service, or security product should be evaluated for its ability to support future cryptographic algorithm changes.

This prevents organizations from introducing additional cryptographic dependencies that will become expensive to replace later.

10. Conclusion

Post-Quantum Cryptography represents one of the most significant developments in the future of information security.

Although large-scale cryptographically relevant quantum computers are not yet available, the potential impact on existing public-key cryptographic systems requires organizations to begin preparing now.

The threat extends beyond encryption. It affects Public Key Infrastructure, Identity and Access Management, Privileged Access Management, digital signatures, secure communications, cloud infrastructure, software development, and third-party technology dependencies.

Organizations should approach PQC as a strategic cybersecurity transformation initiative.

The most important activities are:

1. Understand where cryptography is used.
2. Identify vulnerable RSA and ECC dependencies.
3. Assess the confidentiality lifespan of sensitive information.
4. Adopt NIST-standardized quantum-resistant algorithms.
5. Establish cryptographic agility.
6. Modernize PKI, IAM, PAM, HSM, and network infrastructure where required.
7. Engage technology vendors and assess supply-chain readiness.
8. Develop a phased enterprise migration roadmap.

The key message for cybersecurity leaders is that quantum readiness should begin before quantum computers become a practical threat to today's cryptography.

Organizations that start preparing early will be better positioned to protect confidential information, maintain trust, satisfy evolving security requirements, and minimize the cost and complexity of future cryptographic transitions.

11. References and Further Reading

The following are authoritative technical references suitable for a cybersecurity article, enterprise security strategy, or CISSP-related research.

1. NIST – Post-Quantum Cryptography

National Institute of Standards and Technology.

NIST Post-Quantum Cryptography Project

Provides an overview of PQC research, standards, and migration activities.

2. NIST FIPS 203 – ML-KEM

NIST FIPS 203, 204 and 205 announcement and standards information

Defines the Module-Lattice-Based Key-Encapsulation Mechanism.

3. NIST FIPS 204 – ML-DSA

Module-Lattice-Based Digital Signature Standard

Defines the post-quantum digital signature standard.

4. NIST FIPS 205 – SLH-DSA

Stateless Hash-Based Digital Signature Standard

Defines an alternative hash-based digital signature standard.

5. NIST IR 8547 – Transition to Post-Quantum Cryptography Standards (October 2026)

NIST IR 8547 – Final Report

Provides guidance and timelines for transitioning away from quantum-vulnerable cryptographic standards.

6. NIST – Migration to Post-Quantum Cryptography

NIST NCCoE PQC Migration Project

Provides practical migration information, cryptographic discovery guidance, and frequently asked questions.

7. NIST – Cryptographic Agility (2026)

Considerations for Achieving Cryptographic Agility: Strategies and Practices

Provides recommendations for designing systems that can adapt to changes in cryptographic algorithms.

8. NIST – PQC Standards and Publications

NIST PQC Publications and Technical Reports

Provides additional research, technical reports, and standardization updates.

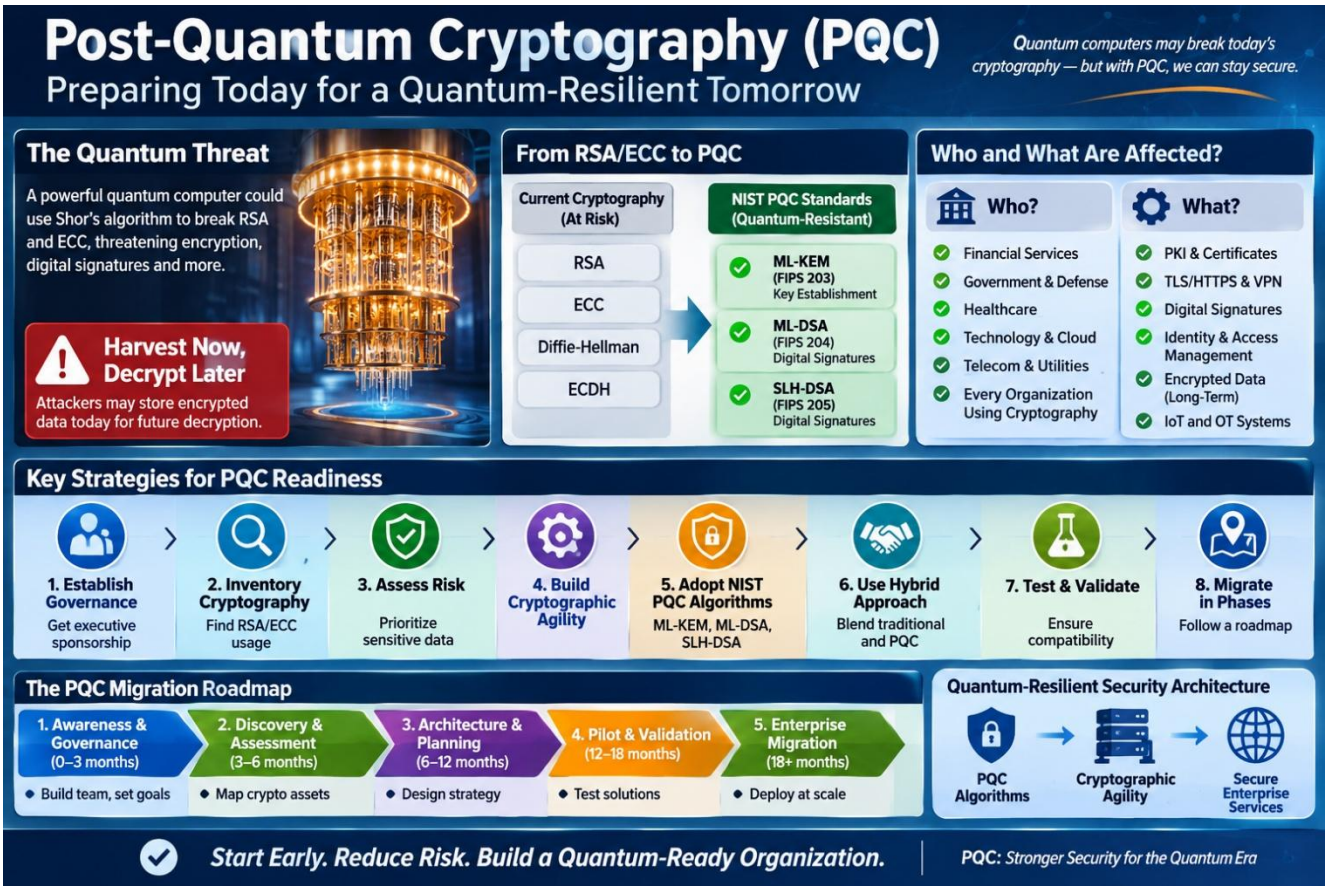
12. Suggested Application to a CISSP Security Architecture Program

For CISSP study and enterprise security architecture, PQC connects particularly well with these domains:

CISSP domain	**PQC relevance**
Domain 1 – Security and Risk Management	Quantum risk assessment, governance, compliance, risk treatment
Domain 2 – Asset Security	Data classification, confidentiality lifespan, information protection
Domain 3 – Security Architecture and Engineering	Cryptography, encryption, PKI, secure architecture

Domain 4 – Communication and Network Security	TLS, VPN, network encryption and secure protocols
Domain 5 – Identity and Access Management	Digital certificates, authentication, signatures and federation
Domain 6 – Security Assessment and Testing	Cryptographic testing, validation and vulnerability assessments
Domain 7 – Security Operations	Key management, certificate lifecycle, monitoring and migration
Domain 8 – Software Development Security	Secure coding, cryptographic libraries, code signing and application modernization

My recommendation: From a CISSP and enterprise security architecture perspective, Domain 3 is the primary domain to study for PQC because it covers cryptographic technologies and security architecture. However, implementing PQC is an enterprise-wide initiative involving all eight domains.



How to Migrate an Application to ML-KEM (Post-Quantum Cryptography)

Migrating an application to ML-KEM (Module-Lattice-Based Key-Encapsulation Mechanism) involves changing how the application establishes encryption keys between communicating systems.

The important point is that ML-KEM does not directly encrypt application data. Instead, it securely establishes a shared secret between two parties. That shared secret is then used to derive symmetric encryption keys, which protect the actual application data.

For an enterprise application currently using RSA or Elliptic Curve Cryptography (ECC), migration to ML-KEM requires changes to its cryptographic architecture, communication protocols, cryptographic libraries, and potentially its infrastructure.

Let's look at this from an enterprise application and security architecture perspective.

1. Understand what needs to change

Consider a traditional application that uses RSA or ECDH to establish a shared encryption key.

Traditional architecture:

1. Application A communicates with Application B.
2. The applications use RSA or ECDH-based mechanisms to establish a shared secret.
3. A symmetric encryption key is derived.
4. AES encrypts the application data.
5. The receiving application decrypts the data.

The concern is that RSA and ECDH key establishment mechanisms are vulnerable to sufficiently powerful quantum computers.

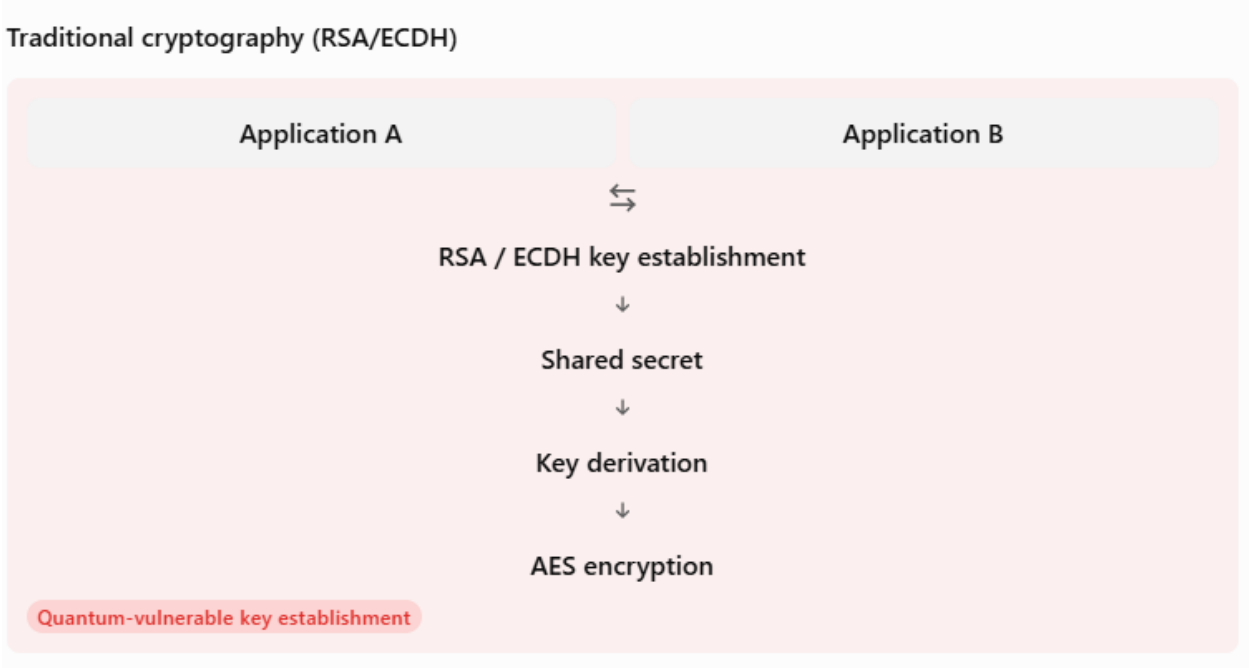
New architecture using ML-KEM:

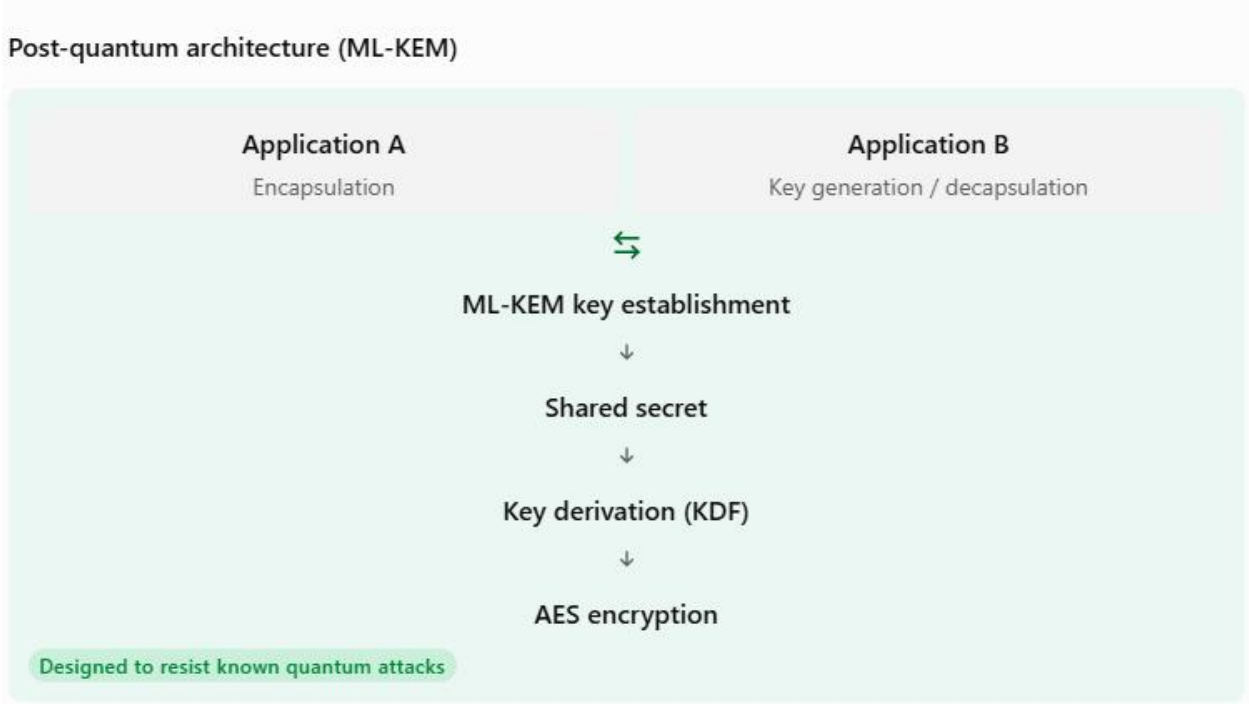
1. Application B generates an ML-KEM key pair.
2. Application B shares its ML-KEM public key with Application A.
3. Application A uses ML-KEM encapsulation to generate a shared secret and an encapsulation value.
4. Application A sends the encapsulation value to Application B.
5. Application B uses its private key to decapsulate the value and obtain the same shared secret.
6. Both applications derive symmetric encryption keys.
7. AES encrypts and decrypts the application data.

The result is a shared secret established using a post-quantum key-encapsulation mechanism.

2. Traditional versus ML-KEM architecture

Traditional cryptography (RSA/ECDH)





The symmetric encryption layer can often remain in place. The main architectural change is the key-establishment mechanism.

3. Choose the migration approach

There are two main approaches to migrating an application.

Approach	Description	Recommended use
TLS-based migration	Upgrade TLS libraries and configure ML-KEM hybrid key exchange	Most web applications, APIs and microservices
Application-level migration	Integrate ML-KEM into the application's cryptographic layer	Applications with custom protocols or specialized key-establishment requirements

My recommendation: For most enterprise applications, start with TLS-based migration. It reduces the need to modify application business logic and centralizes cryptographic changes within the communication infrastructure.

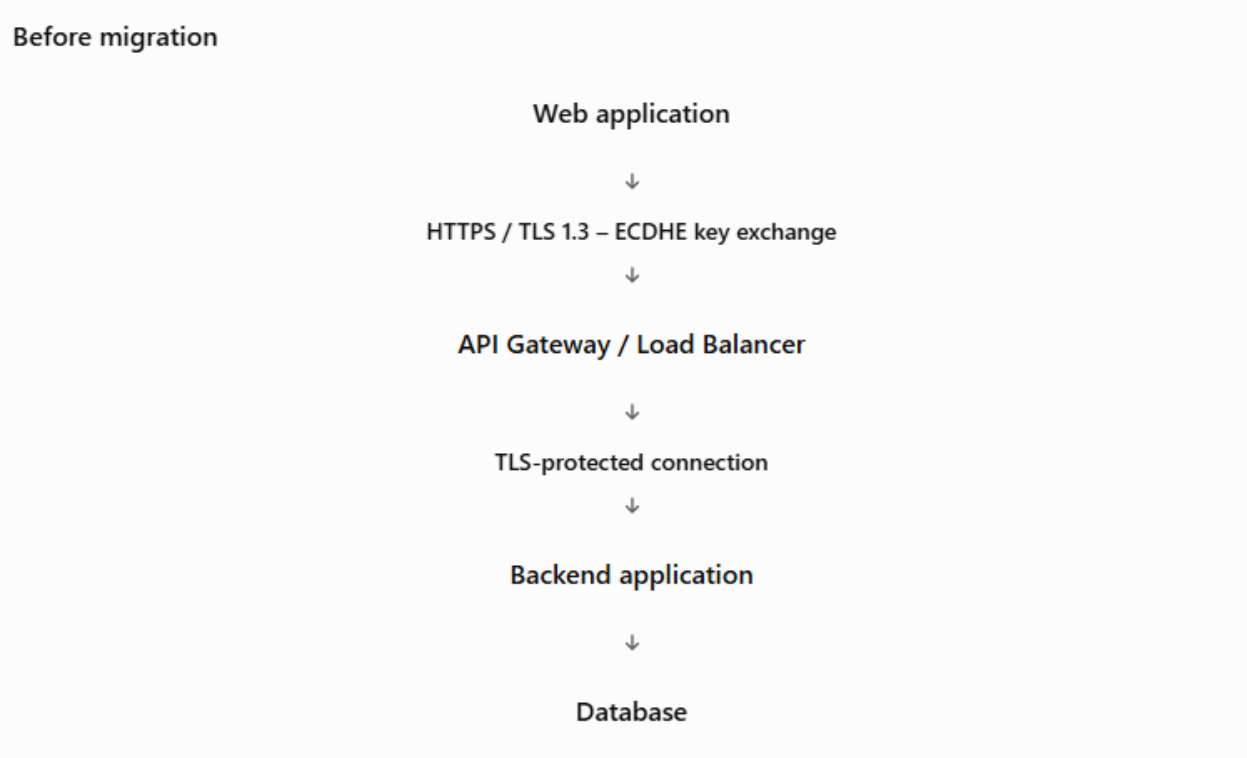
Approach A: Migrate through TLS 1.3

Suppose your organization operates the following application:

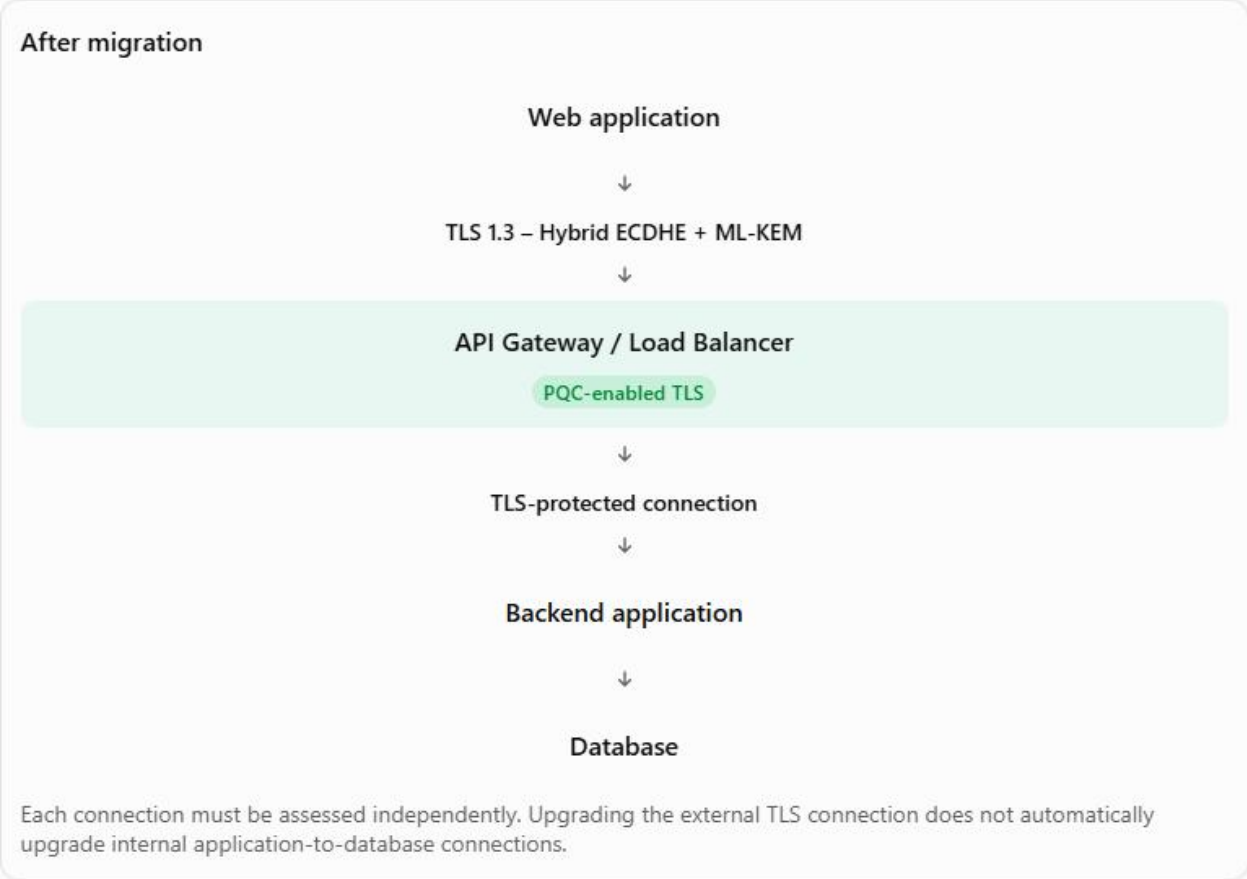
- Frontend: Web application.
- Backend: Java or .NET application.
- API: REST API.
- Database: SQL Server or Oracle.
- Communication: HTTPS using TLS 1.3.

The existing communication architecture might look like this:

Before migration



During migration, the organization upgrades the TLS implementation to support a standardized hybrid key exchange.



In this architecture, the API gateway, web server, or TLS termination point must support the selected ML-KEM hybrid group.

The application business logic can often remain unchanged.

Which TLS hybrid algorithm should be used?

An important development in 2026 is the publication of IETF RFC 10024, which specifies hybrid key agreement mechanisms for TLS 1.3.

These include:

TLS hybrid group	Components
X25519MLKEM768	X25519 + ML-KEM-768
SecP256r1MLKEM768	P-256 + ML-KEM-768
SecP384r1MLKEM1024	P-384 + ML-KEM-1024

These mechanisms combine conventional elliptic-curve key exchange with post-quantum ML-KEM key establishment.

RFC Editor+1

For an enterprise migration, the appropriate group should be selected according to security policy, implementation support, performance, and applicable compliance requirements.

4. Approach B: Integrate ML-KEM into the application

Some applications do not rely exclusively on TLS for establishing cryptographic secrets.

For example:

- Financial transaction applications.
- Secure document exchange systems.
- Internal encryption services.
- Custom enterprise communication protocols.
- Applications using application-level encryption.

These applications may need to integrate ML-KEM into their cryptographic service layer.

Example: Application-to-application communication

Imagine a company has two applications:

- Application A: Financial transaction processing.
- Application B: Financial reporting.

Both applications exchange confidential business information.

The organization wants to protect the communication using ML-KEM.

The migration process would look like this:

ML-KEM application communication flow

Step 1 – Key generation

Application B generates an ML-KEM public key and private key.

Private key remains protected by Application B.

Step 2 – Public-key exchange

Application B securely provides its public key to Application A.

Public-key authenticity must be verified.

Step 3 – Encapsulation

Application A performs ML-KEM encapsulation.

It generates:

- Encapsulation value (ciphertext).
- Shared secret.

Step 4 – Decapsulation

Application A sends the encapsulation value to Application B.

Application B uses its private key to decapsulate the value and derive the same shared secret.

Step 5 – Symmetric key derivation

Both applications derive an encryption key using an approved key derivation function (KDF).

For example, HKDF where appropriate to the protocol.

Step 6 – Data encryption

Application A encrypts the business data using authenticated symmetric encryption, such as AES-GCM.

Application B decrypts and verifies the received data.

This is the general ML-KEM key-establishment lifecycle. The encapsulation value is not the encrypted business data; it is used to establish the shared secret.

The process follows the ML-KEM operations defined in NIST FIPS 203.

NIST Computer Security Resource Center+1

5. Practical application migration steps

Here is a recommended implementation plan for a development and security architecture team.

Step	Technical activity	Responsible team
1	Identify RSA/ECC usage in application code	Application development
2	Identify TLS versions and cryptographic libraries	Infrastructure

3	Select ML-KEM implementation	Security architecture
4	Upgrade TLS and cryptographic libraries	Development / Infrastructure
5	Configure ML-KEM hybrid key exchange	Network / Infrastructure
6	Review certificate and authentication mechanisms	PKI / IAM
7	Conduct application compatibility testing	QA / Security testing
8	Deploy to pilot environment	DevSecOps
9	Migrate production applications	Application owners
10	Monitor and validate cryptographic configurations	Security operations

Step 1: Identify existing cryptographic algorithms

The development team should examine the application's cryptographic dependencies.

For example:

Application component	Existing cryptography	Migration consideration
HTTPS communication	TLS 1.3 / ECDHE	Hybrid ML-KEM key exchange
API communication	TLS / ECDHE	Upgrade TLS implementation
Application encryption	AES-256	Generally retain
Key establishment	RSA or ECDH	Evaluate ML-KEM
Digital signatures	RSA / ECDSA	Separate PQ signature migration
Certificate infrastructure	RSA / ECC	Evaluate future PQ certificate support

Do not assume that every RSA or ECC implementation should be replaced with ML-KEM. ML-KEM replaces key-establishment functionality, not digital signatures.

Step 2: Select the cryptographic library

The development team needs a cryptographic implementation that supports NIST FIPS 203.

The selection criteria should include:

- FIPS 203 compliance.

- Vendor support.
- Secure implementation.
- Supported programming languages.
- Operating system compatibility.
- Hardware acceleration, where relevant.
- Integration with existing TLS libraries.
- Applicable FIPS 140-3 validation requirements.

For enterprise production, use an appropriately validated cryptographic module when required by the organization's compliance obligations.

Step 3: Upgrade the TLS infrastructure

The organization should review its existing TLS infrastructure.

For example:

- Web servers.
- API gateways.
- Load balancers.
- Reverse proxies.
- Service meshes.
- Application servers.
- Client-side TLS libraries.

The objective is to ensure that both communicating endpoints can negotiate the selected hybrid key exchange.

A TLS upgrade on the frontend alone does not guarantee that backend connections are also quantum-resistant.

Step 4: Review authentication and digital signatures

This is a frequently overlooked part of PQC migration.

ML-KEM provides key establishment, but it does not replace digital signature algorithms.

For example, an application might use:

- ML-KEM for key establishment.
- ML-DSA for post-quantum digital signatures.
- AES-256-GCM for symmetric authenticated encryption.

The organization should separately evaluate how RSA and ECDSA signatures used in certificates, software signing, and authentication will eventually be migrated.

Step 5: Test application compatibility

Before production deployment, conduct testing in a controlled environment.

Testing area	What to validate
Functional testing	Applications continue to work
Interoperability	Different application platforms communicate
Performance testing	Handshake latency and resource consumption
Security testing	Correct cryptographic implementation
Network testing	Firewalls and proxies support larger handshake messages
Certificate testing	Existing authentication remains functional
Recovery testing	Rollback and recovery processes work

Pay particular attention to increased public-key and ciphertext sizes, which can affect network infrastructure and application performance.

6. Example: Migrating a Java enterprise application

Consider an enterprise application developed in Java.

Its existing architecture uses:

- Java backend.
- HTTPS communication.
- TLS 1.3.
- RSA/ECDHE-related cryptographic dependencies.
- AES encryption.

- SQL database.

A possible migration approach is:

Existing component	Migration activity
Java application	Review cryptographic dependencies
TLS provider	Upgrade to a version supporting the selected hybrid group
HTTP client	Enable and test hybrid TLS negotiation
Application server	Configure compatible TLS settings
API gateway	Upgrade and enable PQC hybrid support
Database connection	Independently assess TLS support
Key management	Review ML-KEM key handling and lifecycle

The Java application may not require changes to its business logic if the ML-KEM functionality is implemented transparently within the TLS layer.

For application-level ML-KEM, developers would need to integrate the appropriate cryptographic APIs into the application.

The same architectural approach applies to .NET, Python, Go, and other application platforms.

7. Important security considerations

There are several mistakes organizations should avoid.

1. Do not treat ML-KEM as a replacement for AES.

ML-KEM establishes shared secrets. AES performs symmetric data encryption.

2. Do not assume ML-KEM replaces RSA digital signatures.

Digital signatures require a separate migration strategy, including consideration of ML-DSA or SLH-DSA.

3. Do not implement your own cryptographic protocol.

Use standardized protocols and established cryptographic libraries.

4. Do not assume upgrading TLS automatically upgrades every connection.

Review application-to-application, application-to-database, and third-party connections independently.

5. Do not overlook public-key authentication.

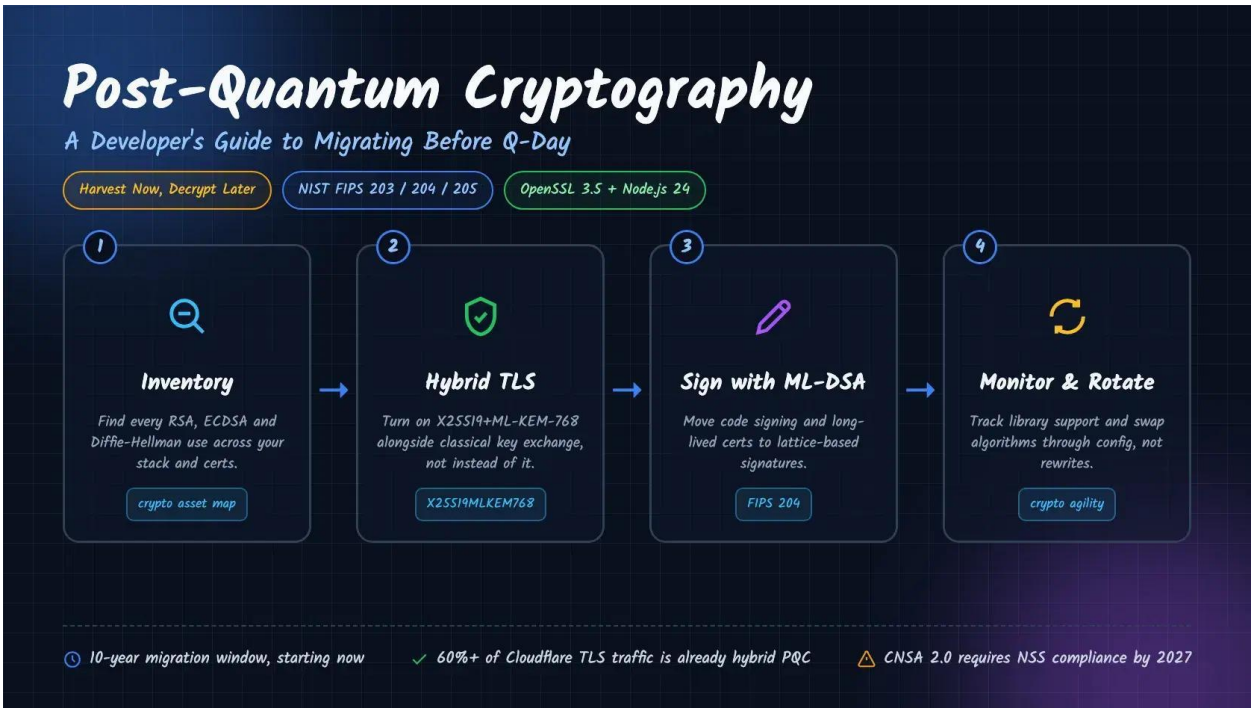
A malicious party could substitute an unauthenticated public key. The application must authenticate the communicating endpoint through an appropriate mechanism.

6. Do not overlook cryptographic key management.

Private keys must be protected, access-controlled, rotated where appropriate, backed up according to policy, and securely retired.

8. Recommended enterprise migration architecture

For an organization with hundreds of applications, I would recommend establishing a centralized PQC-enabled cryptographic service architecture.



Post-Quantum Cryptography Migration: A 2026 Developer's Guide | DevToolLab Blog

devtoollab.com

The architecture should include:

1. PQC-enabled TLS infrastructure: Supports hybrid key exchange.
2. Cryptographic service layer: Provides approved cryptographic implementations.

3. HSM and key management: Protects cryptographic key material.
4. PKI modernization: Supports future quantum-resistant authentication and signatures.
5. Application integration: Enables applications to use standardized cryptographic services.
6. Monitoring and governance: Tracks cryptographic algorithms, versions, and migration status.

This approach reduces the need for every application team to independently design and implement its own cryptographic solution.

9. Recommended migration priorities

For a practical enterprise implementation, I would prioritize the work as follows:

Application PQC migration checklist

Migration progress

0/10

- Inventory application RSA and ECC dependencies
- Identify TLS termination points and internal connections
- Identify applications handling long-term sensitive information
- Select an approved ML-KEM implementation
- Upgrade TLS libraries and supporting infrastructure
- Enable and test hybrid TLS key exchange
- Review PKI, certificates and digital signatures separately
- Validate application performance and interoperability

Conduct security testing and vendor assessments

Deploy progressively and monitor production

10. References and technical documentation

These are useful primary references for the implementation team.

1. NIST FIPS 203 – ML-KEM Standard

NIST Module-Lattice-Based Key-Encapsulation Mechanism Standard

Defines ML-KEM-512, ML-KEM-768 and ML-KEM-1024.

2. IETF RFC 10024 – Hybrid Key Agreement for TLS 1.3

Post-Quantum Traditional Hybrid Key Agreement Mechanisms for TLS 1.3

Defines the ML-KEM and ECDHE hybrid groups for TLS 1.3.

3. IETF RFC 9954 – Hybrid Key Exchange

Hybrid Key Exchange in TLS 1.3

Explains the architecture for combining conventional and post-quantum key exchange.

4. NIST SP 800-227 – Recommendations for Key-Encapsulation Mechanisms

NIST Recommendations for Key-Encapsulation Mechanisms

Provides guidance for the secure use of KEMs.

11. Final recommendation

For an enterprise CISO or security architect, I would not recommend immediately modifying hundreds of applications to implement ML-KEM individually.

Instead, use a centralized migration strategy:

- First, identify applications using RSA and ECC.
- Second, upgrade common TLS infrastructure to support ML-KEM hybrid key exchange.
- Third, migrate application-level encryption services where necessary.
- Fourth, modernize digital signatures and PKI separately.
- Finally, establish cryptographic agility to support future algorithm changes.

The key architectural principle is: migrate the cryptographic layer first, minimize changes to business logic, and progressively modernize application dependencies.

This approach can significantly reduce the complexity, cost, and operational risk of enterprise PQC migration.

I can also develop a detailed Java or .NET ML-KEM implementation example.